PROJET SPÉCIALITÉ CYBERSÉCURITÉ

Livrable : Architecture de Sécurité

TechnoSite Industrie

Schéma d'architecture + Justification des choix techniques

Réaliser Clément VAN MELKEBEKE & Moumou idir

1. Introduction et contexte

Le modèle choisi adopte le concept du défense en profondeur (Defense-in-Depth), en intégrant plusieurs niveaux de protection autonomes pour éviter qu'une seule défaillance ne mette en péril la totalité du système. Elle se base sur les normes suivantes :

- IEC 62443 — Sécurité des systèmes industriels (OT)
- ANSSI — Guide de cloisonnement réseau (PAMS)
- NIST CSF (Identify, Protect, Detect, Respond, Recover)
- Modèle Purdue pour la ségrégation IT/OT

2. Schéma d'architecture de sécurité

Le schéma ci-dessous représente l'architecture globale du site TechnoSite Industrie:

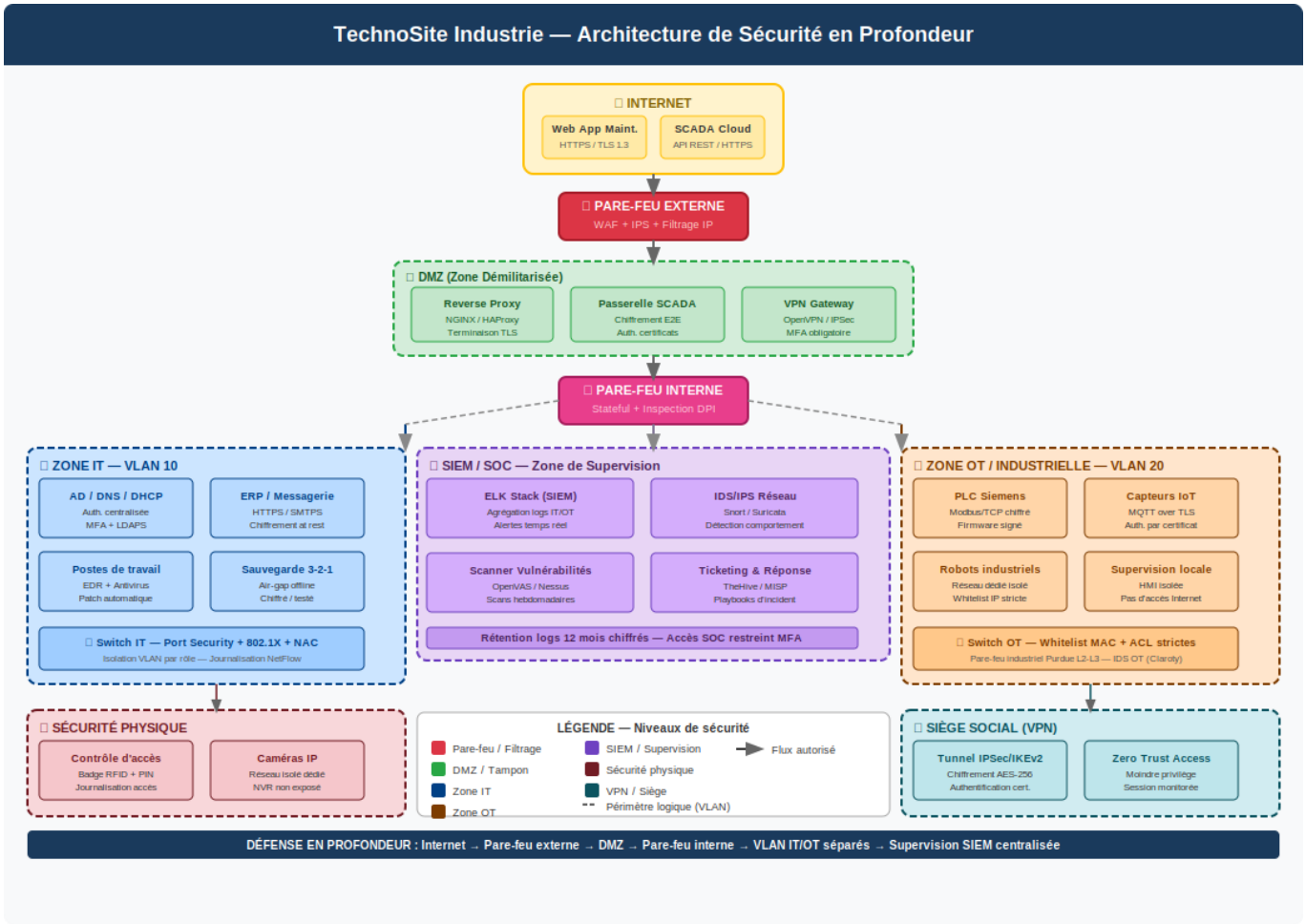

Figure 1 — Architecture de sécurité en profondeur — TechnoSite Industrie (2026)

3. Description des zones de sécurité

3.1 Zone Internet et exposition externe

Deux services sont exposés sur Internet : l'application web de maintenance à distance (HTTPS) et la passerelle SCADA cloud. Ces points d'entrée représentent la surface d'attaque externe principale identifiée dans l'analyse EBIOS.

Composant	Protocole	Mesure de sécurité
Application web maintenance	HTTPS / TLS 1.3	WAF, rate limiting, auth MFA
API SCADA Cloud	REST / HTTPS	OAuth2, certificats mutuels, IP allowlist
VPN Siège	IPSec / IKEv2	Certificats PKI, MFA, audit de sessions

3.2 Pare-feu externe et WAF

Le pare-feu externe constitue le premier rempart entre Internet et le réseau interne. Il est couplé à un Web Application Firewall (WAF) pour protéger l'application web.

- Filtrage stateful : inspection des états de connexion TCP/UDP
- WAF : protection contre injection SQL, XSS, CSRF (OWASP Top 10)
- IPS (Intrusion Prevention System) : blocage automatique des signatures d'attaque connues
- Géo-blocage : restriction des connexions aux zones géographiques autorisées
- Logs centralisés vers SIEM avec alertes temps réel

3.3 Zone DMZ (Zone Démilitarisée)

La DMZ est une zone tampon entre Internet et le réseau interne. Elle héberge les services accessibles depuis l'extérieur, isolés du réseau de production. Toute communication entre Internet et le réseau interne transite obligatoirement par la DMZ.

- Reverse Proxy (NGINX/HAProxy) : terminaison TLS, masquage de l'infrastructure interne
- Passerelle SCADA : relais chiffré entre le cloud fournisseur et le SCADA interne
- VPN Gateway : point de terminaison VPN avec authentification forte (MFA + certificats)
- Aucune connexion directe possible depuis Internet vers les zones IT/OT

3.4 Pare-feu interne

Un second pare-feu sépare la DMZ du réseau interne. Il applique une inspection approfondie des paquets (DPI) et garantit que seuls les flux légitimes et nécessaires sont autorisés. Le principe de moindre privilège est appliqué : tout ce qui n'est pas explicitement autorisé est bloqué.

3.5 Zone IT — VLAN 10

La zone IT héberge les systèmes bureautiques : Active Directory, ERP, messagerie et postes de travail. Elle est isolée de la zone OT par une règle de pare-feu stricte, autorisant uniquement les flux nécessaires et tracés.

Composant	Sécurité appliquée	Justification
Active Directory	MFA (TOTP), LDAPS, tiering admin	Éviter la compromission des comptes de service
ERP / Messagerie	HTTPS, chiffrement at rest, DLP	Protection des données de production et clients
Postes de travail	EDR, patch management auto, AppLocker	Réduction de la surface d'attaque endpoint
Sauvegarde 3-2-1	Air-gap, chiffrement AES-256, tests mensuels	Résilience face aux ransomwares

3.6 Zone OT / Industrielle — VLAN 20

La zone OT est la plus critique : elle contrôle directement les automates PLC, les robots et les capteurs IoT du site de production. Elle applique les recommandations IEC 62443 et le modèle Purdue de ségrégation.

- Isolation réseau complète : aucun flux non autorisé entre IT et OT (pare-feu industriel dédié)

- Protocoles industriels sécurisés : Modbus/TCP sur canal chiffré, MQTT over TLS (MQTTs)
- Whitelist applicative : seules les communications nécessaires entre PLC/HMI sont autorisées
- Pas d'accès Internet depuis la zone OT : les PLC et robots ne peuvent pas initier de connexion sortante
- IDS industriel (ex. Claroty, Dragos) : surveillance comportementale spécifique aux protocoles OT
- Firmware signé sur les PLC : intégrité vérifiée au démarrage

3.7 Supervision SIEM / SOC

Un système de gestion centralisée des événements de sécurité (SIEM) basé sur la stack ELK (Elasticsearch, Logstash, Kibana) collecte et corrèle les logs de toutes les zones. Il constitue la capacité de détection et de réponse aux incidents.

- Agrégation des logs : tous les équipements (pare-feux, AD, PLC, IoT, caméras) envoient leurs logs en temps réel
- IDS réseau (Snort/Suricata) : détection des comportements anormaux sur les flux réseau
- Scanner de vulnérabilités (OpenVAS/Nessus) : scans hebdomadaires de l'ensemble du périmètre
- Gestion des incidents (TheHive/MISP) : traçabilité, playbooks automatisés, corrélation avec bases de threat intelligence
- Rétention des logs : 12 mois minimum, stockage chiffré, accès restreint au personnel SOC avec MFA

3.8 Sécurité physique

La sécurité physique est intégrée à l'architecture globale car une intrusion physique peut contourner toutes les mesures logiques. Les caméras IP sont isolées sur un réseau dédié non routé vers Internet.

- Contrôle d'accès : badges RFID + code PIN (double facteur physique), journalisation de tous les accès
- Caméras IP : réseau VLAN dédié, enregistreur NVR non exposé, accès sécurisé par VPN interne
- Armoires électriques et baies serveurs : verrous physiques, détection d'ouverture

3.9 Liaison VPN avec le siège social

La connexion avec le siège social utilise un tunnel IPSec/IKEv2 avec chiffrement AES-256. Le principe Zero Trust est appliqué : les utilisateurs du siège n'ont accès qu'aux ressources dont ils ont explicitement besoin, et leurs sessions sont monitorées par le SIEM.

4. Tableau de synthèse des mesures de sécurité

Le tableau ci-dessous récapitule l'ensemble des mesures de sécurité mises en place, organisées par domaine de la défense en profondeur, avec leur priorité de déploiement.

Couche	Mesure	Outil / Technologie	Priorité
Réseau	Segmentation VLANs IT/OT	Switches managés 802.1Q	Critique
Réseau	Pare-feux externe + interne	FortiGate / pfSense + WAF	Critique
Réseau	DMZ avec reverse proxy	NGINX, HAProxy	Critique
Authentification	MFA sur tous les accès distants	TOTP + PKI (certificats)	Critique
Chiffrement	TLS 1.3 partout (HTTPS, MQTTS)	Let's Encrypt / PKI interne	Critique
Surveillance	SIEM centralisé (ELK Stack)	Elasticsearch, Logstash, Kibana	Élevée
Surveillance	IDS/IPS réseau	Snort / Suricata	Élevée

Couche	Mesure	Outil / Technologie	Priorité
OT	Pare-feu industriel + IDS OT	Claroty / Dragos	Élevée
Résilience	Sauvegarde 3-2-1 + air-gap	Veeam + stockage hors ligne chiffré	Élevée
Endpoint	EDR + patch management	CrowdStrike / Defender for Endpoint	Élevée
Physique	Badges RFID + PIN + caméras isolées	Système RFID + NVR dédié	Moyenne
Organisationnel	Formation anti-phishing	Programmes de sensibilisation	Moyenne
Organisationnel	PRA / PCA documenté	Plan de reprise testé annuellement	Moyenne
Vulnérabilités	Scans et pentest réguliers	OpenVAS, Nessus, tests manuels	Moyenne

5. Justification des choix architecturaux

5.1 Pourquoi la défense en profondeur ?

Les risques identifiés dans l'analyse EBIOS démontrent que l'entreprise fait face à des menaces multiples et hétérogènes (phishing, injection SQL, pivot IT/OT, ransomware). Une architecture à périmètre unique serait insuffisante : si un attaquant pénètre le réseau via une vulnérabilité applicative, il ne doit pas pouvoir atteindre directement les automates industriels.

La défense en profondeur garantit qu'un attaquant doit franchir successivement plusieurs barrières indépendantes, chacune capable de détecter et bloquer l'intrusion. Le principe est aligné avec les recommandations de l'ANSSI pour les OIV (Opérateurs d'Importance Vitale).

5.2 Pourquoi isoler strictement la zone OT ?

Les systèmes OT (PLC, robots) ont des contraintes spécifiques : ils ne peuvent pas être patchés fréquemment, ils utilisent des protocoles non chiffrés historiquement (Modbus), et une panne peut entraîner des conséquences physiques graves (sécurité des personnes, pertes de production). La compromission d'un PLC est un scénario de risque critique selon EBIOS.

L'isolation stricte via pare-feu industriel, whitelist IP et VLAN dédié garantit qu'un attaquant ayant compromis la zone IT ne peut pas pivoter automatiquement vers l'OT. La surveillance spécifique via un IDS OT permet de détecter les comportements anormaux sur les protocoles industriels.

5.3 Pourquoi le SIEM est-il central ?

Sans capacité de détection, les mesures préventives sont insuffisantes — un attaquant sophistiqué finira par contourner les barrières. Le SIEM permet de corréler des événements a priori anodins (un scan réseau, une connexion inhabituelle à 3h du matin, un accès ERP hors horaires) pour détecter une intrusion en cours avant qu'elle n'atteigne ses objectifs. Il constitue la capacité de réponse à incident (CSIRT) minimale du site.

5.4 Alignement avec EBIOS RM

Chaque mesure de l'architecture répond à un ou plusieurs scénarios de risque identifiés dans l'analyse EBIOS :

Scénario EBIOS	Mesure architecturale correspondante
Sabotage PLC via pivot IT→OT	Isolation VLAN OT + pare-feu industriel + IDS OT
Ransomware affectant IT et SCADA	Sauvegarde 3-2-1 air-gap + isolation SCADA en DMZ
Phishing ciblé technicien	MFA + EDR + formation + SIEM (détection connexion anormale)
Injection SQL sur app web	WAF + patch TLS + scan vulnérabilités + reverse proxy DMZ
Intrusion physique / badge cloné	Double facteur RFID+PIN + journalisation + caméras réseau isolé

Scénario EBIOS	Mesure architecturale correspondante
Exfiltration MQTT en clair	MQTT over TLS (MQTTs) + authentification par certificat IoT